Computers & Security 154 (2025) 104411

Contents lists available at ScienceDirect

Computers & Security

journal homepage: www.elsevier.com/locate/cose

Full length article

Systematic analysis of security advice on the topic of insider threats

Andrew Stewart *, Christopher Hobbs

King's College London, United Kingdom

ARTICLE INFO

Keywords:
Insider threat
Security advice
Qualitative coding
Systematic analysis

ABSTRACT

Insider threats are an important and enduring security challenge. As a consequence, a number of organizations such as government agencies, research institutions, trade groups, and other parties have published documents containing advice on the topic of insider threats. Here, we provide an evaluation of such advice documents. We employ the relatively new SAcoding (security advice coding) methodology to perform a systematic analysis. This approach enables us both to assess the advice documents and to provide feedback on the use of SAcoding for a novel category (advice intended specifically for organizations), and for a novel topic (advice on the topic of insider threats). We find that 62.5% of 424 advice items extracted from six source documents are actionable, but the per-document proportion of actionable advice ranges substantially from 85.4% to just 35.1%. This finding suggests that organizations may incur opportunity costs by engaging with documents that offer little actionable advice. We also find that organizations may struggle to apply the published guidance, due to the high quantity of advice and the high portion of advice that requires specialist expertise. We use these and other findings to deliver a practical framework that provides guidance for the authors of advice documents, and for organizations seeking advice on the topic of insider threats. Additionally, we provide feedback on various aspects of the SAcoding method.

1. Introduction

As commonly defined, an insider threat involves an individual with authorized access to an organization carrying out some harmful action—either wittingly or unwittingly (Luckey et al., 2019; NIST, 2024). The impact of insider threat incidents is experienced by organizations in a diverse range of fields, including financial services (Epstein, 2008), aviation (Wallace and Loffi, 2014), casino gambling (Dill and Rubin, 2004) food processing and distribution (Pilch and Zilinskas, 2005), and the arts (Michaud, 2010). The harm created by malicious insiders takes various forms, including espionage (Wilder, 2017), fraud (Petrie and Evans, 2019), sabotage (Claycomb et al., 2013), theft (Bunn and Sagan, 2016), and violence (BaMaung et al., 2018).

Because of these challenges, a number of government agencies, research institutions, trade groups, and other parties have authored documents with the goal of helping organizations to address insider threats. If the security advice within these documents is beneficial to organizations, then they represent a public good. But conversely, if the advice is *not* beneficial, then the documents are imposing costs on organizations and potentially reducing security. Exploring the quality of these documents therefore has value.

In this paper, we provide an analysis of documents that provide advice to organizations on the topic of insider threats. We follow Barrera et al. (2023b) and Bellman and van Oorschot (2023) in performing both an informal and systematic analysis of security advice. Whereas those authors analyze documents that provide advice on the topic of IoT (Internet of Things), our focus here is the analysis of advice on the topic of insider threats.

Fig. 1 illustrates the research phases and overall flow. For the informal analysis we first examine pertinent properties of the documents such as their stated audience and purpose, the terminology they employ, their theoretical grounding, and their research design. For the systematic portion we then identify the degree to which the advice within the documents is *actionable*, using the SAcoding methodology created by Barrera et al. (2023b).

Our evaluation highlights significant variation in the proportion of actionable advice across the documents examined, limited provision of methodological detail, inconsistent and sometimes contradictory use of terminology, wide variation in the types of expertise required to implement the advice, and inadequate provision of references in some cases. We note the implications for organizations, such as the difficulty

* Corresponding author.
E-mail addresses: andrew.james.stewart@kcl.ac.uk (A. Stewart), christopher.hobbs@kcl.ac.uk (C. Hobbs).

https://doi.org/10.1016/j.cose.2025.104411
Received 19 August 2024; Received in revised form 21 January 2025; Accepted 28 February 2025
Available online 17 March 2025
0167-4048/© 2025 Elsevier Ltd. All rights are reserved, including those for text and data mining, AI training, and similar technologies.

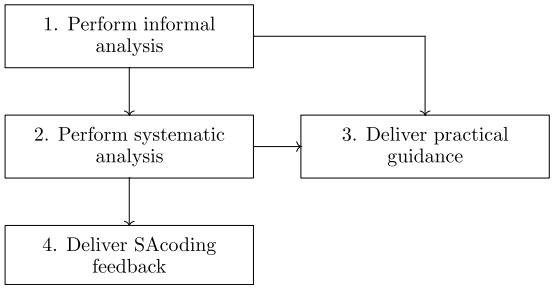

Fig. 1. Research phases and overall flow. Arrows indicate path dependence, illustrating how prior phases inform subsequent phases.

of evaluating advice documents, the risk of incurring opportunity costs by engaging with documents that offer little actionable advice, and the need to acquire supplementary sources of information, amongst other findings. We also offer a number of items of practical guidance for the authors of advice documents and for organizations seeking advice on the topic of insider threats. As a further contribution, we provide feedback on the relatively new SAcoding methodology, by making four observations regarding possible improvements.

Because the topic of security advice naturally involves both a producer and a consumer, we believe these contributions can benefit both academia—the producers of advice, and organizations—the consumers of advice, in the round.

2. Source documents

A large number of documents providing advice on the topic of insider threats exist. Specific criteria were therefore employed to narrow the identification of source documents to the types of document that an organization searching for advice on the topic of insider threats might reasonably encounter. Namely, documents were required to be:

1. Focused specifically on providing advice to organizations on the topic of insider threats
2. Containing advice items that are clearly identifiable.
3. Authored by a reputable organization.
4. Available online at no cost.
5. Published within the prior ten years.

Web searches were used to carry out the document search, since this is plausibly the most likely method that organizations would also employ. Because reputation is a subjective quality, we employed a conservative approach in assessing the reputability of organizations, meaning only those organizations that in our view are plainly reputable were selected. As a result of the search, six documents were identified:

- The *Insider Threat Mitigation Guide* is authored by the Cybersecurity and Infrastructure Agency (CISA) (CISA, 2020). The CISA is the U.S. government agency responsible for cybersecurity and infrastructure protection, and is part of the U.S. Department of Homeland Security.
- The *Insider Threat Program Development Manual* is authored by the Confederation of European Security Services (COESS) (COESS, 2019). COESS is an umbrella organization for 22 national federations focused on private security services, primarily in the European Union. These organizations include the British Security Industry Organization and the Swedish Security Industry Association.
- *Insider Threats: Effective Controls and Practices* is authored by the Financial Industry Regulatory Authority (FINRA) (FINRA, 2023). FINRA is a regulatory organization that regulates all securities firms operating in the United States.
- The *Insider Threat Guide: A Compendium of Best Practices to Accompany the National Insider Threat Minimum Standards* is authored by the National Insider Threat Task Force (NITTF) (NITTF, 2024). The NITTF is a part of the National Counterintelligence and Security Center that leads counterintelligence for the U.S. government.
- The *CERT Common Sense Guide to Mitigating Insider Threats (7th edition)* is authored by the Software Engineering Institute at Carnegie Mellon University (SEI-CERT, 2023). The Software Engineering Institute is a research and development center funded by the U.S. government. The first edition of this document was published in 2005. Researchers at the Software Engineering Institute have published several articles on the topic of insider threats, such as Costa et al. (2016) and Claycomb and Nicoll (2012).
- The *Insider Threat Best Practices Guide (2nd edition)* is authored by the Securities Industry and Financial Markets Association (SIFMA) (SIFMA, 2018). SIFMA is a U.S. industry trade group that represents organizations that operate in the financial services sector, such as investment banks and securities firms.

The authors of the identified documents represent a spectrum of types of organization. CISA is a government agency focused on cyber threats, COESS is a security employers' organization, FINRA is a regulatory body, NITTF is a government agency focused on counterintelligence, SEI-CERT is a research institution, and SIFMA is an industry trade group. Additionally, COESS is based in Europe, while the other organizations are based in the United States—creating geographic diversity. Hereafter, we refer to the six source documents as the CISA, COESS, FINRA, NITTF, SEI-CERT, and SIFMA documents.

3. Informal analysis

As a precursor to the systematic analysis, an informal analysis was first carried out. This analysis investigated pertinent aspects of the source documents, namely: audience, purpose, terminology employed, theoretical grounding, and research design.

Audience. All six source documents squarely target organizations as their intended audience, although they differ in their particular focus. Regarding the intended audience we can further distinguish between the *type* and *size* of target organization. Regarding the *type* of target organization, the CISA document casts the widest net by including organizations from both the public and private sector ("*federal, state, local, tribal, and territorial governments; non-governmental organizations; and the private sector*"). In contrast, the FINRA document states that it was created specifically for "*member firms*"—meaning securities firms doing business in the United States. The COESS document also targets a distinct audience, namely "*aviation & transportation and critical infrastructure stakeholders*". The NITTF document is intended for use by U.S. government departments and agencies. The SEI-CERT document identifies eight specific groups within organizations as its specific audience (which it describes as stakeholders), such as management, legal counsel, information technology, and information security. The SIFMA document is the only document to specify both a primary audience: organizations operating in the financial services sector, and a secondary audience: financial industry regulators.

Regarding the *size* of target organization, the CISA document states that it provides "*a proven framework that can be tailored to any organization regardless of size*", and that it can provide value "*for a wide range of individuals and organizations, from the solo practitioner in a small company ... up to and including a sizeable agency that has a staff capable of operating a full complement of insider threat professionals*". The FINRA document states that the advice within the document should be considered by organizations based in part on their size, and provides a link to a 'small firm cybersecurity checklist'. Although the SEI-CERT document does not specify the intended size of target organization, it does identify certain advice items as being specifically for 'large

	CISA	COESS	FINRA	NITTF	SEI-CERT	SIFMA
Guidance	•	•	•	•	•	•
Best Practices	•	•		•	•	•
Measures	•	•		•	•	
Recommendations	•				•	•
Strategies	•	•			•	
Guidelines	•			•		•
Principles	•	•		•		
Procedures	•	•		•		
Approaches	•	•				
Concepts	•	•				
Mitigations		•			•	
Capabilities	•					
Options	•					
Controls			•			
Tactics					•	
Solutions					•	
Assistance						•

Fig. 2. Distribution of terms used to describe advice items within the source documents. • symbol indicates use of corresponding term.

organizations' (although it does not define this term). The COESS, NITTF, and SIFMA documents do not comment on target organization size.

Purpose. The documents share a stated purpose of enabling organizations to develop insider threat programs:

- "*to help . . . establish or enhance an insider threat program*" (CISA)
- "*to provide direction to . . . stakeholders wishing to implement basic building blocks of an insider threat program*" (COESS)
- "*helping member firms identify, prevent, detect and respond to insider threats*" (FINRA)
- "*to help insider threat managers overcome common challenges and establish functional programs with fewer complications*" (NITTF)
- "*to build and sustain high-impact insider risk management programs*" (SEI-CERT)
- "*to provide general guidance and assistance to organizations seeking to establish and implement an effective insider threat program*" (SIFMA)

The SIFMA document specifies two additional goals, to "*act as a reference for regulators to better understand the insider threat at financial institutions*", and "*to help financial firms measure their insider threat program's effectiveness*".

Terminology employed. A total of 17 different terms are used within the source documents to describe advice, with their distribution illustrated in Fig. 2. The most common term is *guidance*—which is used in all six documents. Five of the documents use the term *best practices*, and four documents use the term *measures*. The FINRA document is the most circumspect, describing the advice as only *guidance* and *controls*. In contrast, the CISA document uses 12 different terms, including 2 terms not used to describe advice in any other document. While all of the documents express the same fundamental goal (which is to assist organizations in developing insider threat programs as noted above), the terms employed within the documents to describe their advice vary substantially in meaning. The terms *guidance*, *best practices*, *recommendations*, *guidelines*, *measures*, *strategies*, *tactics*, *approaches*, and *procedures* are all broadly action-oriented, and so align with the goal of providing assistance. In contrast, a *concept* is simply an abstract idea, and so is unlikely to be actionable. Additionally, terms such as *capability*, *control*, and *mitigation* would appear to simply describe end-goals. As Barrera et al. (2023b) note, simply providing an end-goal is not useful unless the reader is also provided with a description of how to achieve that goal. (We explore this aspect further in Section 4.) The use of terms across the source documents is uneven, but the document authors might simply not have considered these aspects. A plausible explanation for the heavy tail shown in Fig. 2 is the presence of multiple contributors to the CISA, COESS, and SEI-CERT documents, each with different knowledge or preferences regarding particular terms. Indeed, the COESS document lists eight authors, and the SEI-CERT document lists seven. Neil et al. (2023) find that a collaborative approach is often valued by the authors of advice documents, in part because those authors believe it reduces workload.

Theoretical grounding. All six of the documents affirm that their contents are based on external evidence. Both the FINRA and SIFMA documents state that their contents are based on the experiences of organizations (FINRA: "*effective controls and practices observed by FINRA*"; SIFMA: "*surveyed financial services firms*"). However, the FINRA and SIFMA documents do not provide any information regarding the organizations surveyed. The contents of the COESS document are described as being "*the results of workshops and discussions and the many experts who were involved in its creation*". The document names one of those workshops, refers to two others (but does not name them), and states that the FBI Insider Threat Division was a workshop participant. The CISA document states that it "*draws from the expertise of some of the most reputable experts in the field*", but does not name those experts. The authors of the NITTF describe the contents as being "*the result of NITTF's continuous training and assistance discussions with the USG [United States Government] insider threat community as well as experience in assessing the progress of more than 97 D/As [Departments/Agencies] implementing the minimum standards*". The SEI-CERT document provides the most detail, with the authors describing the contents as being based on a database of more than 3000 insider incidents. That database is described in the document and in a separate book (Cappelli et al., 2012, pp. 307–318).

Research design. While the source documents do not explicitly specify the goal of academic rigor, the warrant for the claim that the advice within the documents will aid organizations rests on the information within the documents being relevant and applicable, and upon the use of a sound underlying methodological approach. If no backing is provided—such as information regarding the organizations surveyed or what methodology was employed—then the ability to assess the validity of that claim is reduced. Only two documents (SEI-CERT and CISA) provide such a research design. The authors of the SEI-CERT document identify common features of insider incidents and their corresponding probabilities using their database of insider incidents. The CISA document states that it employs a case study approach, and provides one case study in each of the eight main chapters. Those case studies appear to be based on information that is already in the public domain, such as with the case of the 2014 Fort Hood shootings.

The COESS document similarly provides five "*abbreviated case studies*", but these are also based on publicly available information. The SIFMA document contains eight case studies of "*reported insider incidents that have recently occurred at financial institutions*", but those case studies are not described as contributing to the rationale for the advice within the document.

3.1. Summary of informal analysis

The source documents identify organizations as their target audience and express the same fundamental purpose, which is to assist those organizations with the development of their insider threat programs. However, the terminology used across the documents to characterize the advice varies substantially in meaning. Some of the terms employed imply that the advice would not support the declared goal. Although all six source documents state that their contents are grounded in external evidence, only the SEI-CERT document describes the underlying data. The SEI-CERT document is also the only document to provide information regarding the research design employed. We now build upon these observations with a corresponding systematic analysis.

4. Systematic analysis

The SAcoding (security advice coding) method was selected for the purpose of performing a systematic analysis of the source documents. SAcoding was designed by Barrera et al. (2023b) as a generic method for analyzing security advice, with the focus of the method on identifying the *actionability* of advice. Actionable advice, as defined by Bellman and van Oorschot (2023), provides "*an action or unambiguous sequence of steps, whose means of execution is understood*". Actionability is therefore a key property of security advice, since if advice is *not* actionable then it is unlikely to be useful to the reader. In addition to identifying whether security advice is actionable, the method categorizes why advice is (or is not) actionable. For example, an item of advice might be found not to be actionable because it is unfocused, or because it is infeasible. The SAcoding method is therefore a good fit for the purpose of the systematic analysis.

The SAcoding method treats security advice as qualitative data, and operates on that data in the form of a binary coding tree. At each node in the tree the coder is asked a question which leads them to either a further question, or to a leaf node—which is a code. Fig. 3 illustrates the SAcoding algorithm, where Q_n refers to the corresponding question in Fig. 4. The resulting codes (leaf nodes) are described in Fig. 5, with codes that are actionable marked with an asterisk.

In this paper, we employ the version of the SAcoding method described in Barrera et al. (2023a), which updates the SAcoding method with minor changes (one question is split into two resulting in two codes, and another question is removed resulting in two codes being merged).

In order to apply the SAcoding method to the source documents, the advice items were first identified and extracted. Advice items were identified within the source documents as those portions of the text that were explicitly identified by the authors as presenting security advice. These were as follows:

- The CISA document contains an appendix titled "*Summary of Key Points*" that contains 73 advice items (CISA, 2020, pp. 107–113). These items are organized into 6 categories which align with the chapter titles within the document, such as "*Defining Insider Threats*", and "*Detecting and Identifying Insider Threats*".
- The COESS document generally presents advice items as bullet points in the chapter introductions, although sometimes also in the body text. There are 133 identifiable advice items.
- The FINRA document contains a section titled "*Effective Controls and Practices*" that contains 51 advice items in 9 categories such as "*Privileged User Controls*" and "*Identifying Malicious Insiders*" (FINRA, 2023, pp. 2–9).

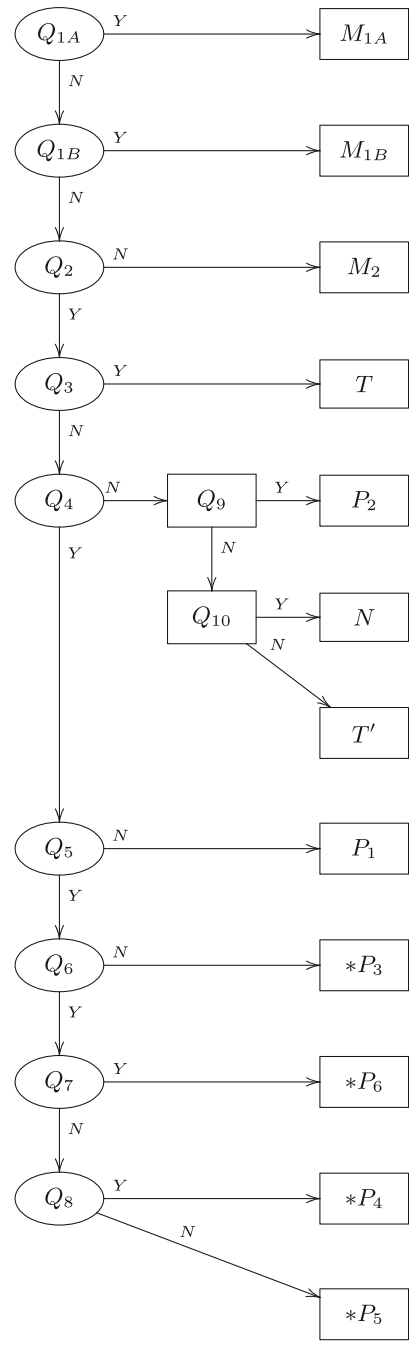

Fig. 3. SAcoding algorithm. Q_n refers to the questions listed in Fig. 4. The resulting codes are described in Fig. 5. $*$ donates actionable codes.

- The NITTF document highlights advice items at the beginning of each chapter in the form of a numbered list (e.g. NITTF, 2024, p. 15). Each list of advice items is then expanded upon in that chapter. The total number of advice items is 31.
- The SEI-CERT document states that it contains "*22 actionable best practices that organizations can leverage to manage insider risk*". Each best practice is a distinct chapter in the document, and each chapter lists between 2 and 13 "*quick wins and high-impact solutions*" that summarize the contents of that chapter. In total, there are 122 such advice items.
- The SIFMA document provides a list of 14 advice items under the heading "*Summary of Best Practices*" (SIFMA, 2018, pp. 6–7).

No.	Question
Q_{1A}	Is the advice item unfocused?
Q_{1B}	Is the advice item unclear?
Q_2	Is it arguably helpful for security?
Q_3	Is it focused more on a desired outcome than how to achieve it?
Q_4	Does it suggest a security technique, mechanism, software tool, or specific rule?
Q_5	Does it describe or imply steps or explicit actions to take?
Q_6	Is it viable to accomplish with reasonable resources?
Q_7	Is it intended that the end-user carry out this item?
Q_8	Is it intended that a security expert carry out this item?
Q_9	Is it a general policy, general practice, or general procedure?
Q_{10}	Is it a broad approach or security property?

Fig. 4. SAcoding questions.

Code	Name	Description
P_1	Incompletely Specified Practice	Advice that lacks indication of steps to take.
P_2	General Policy/Practice	Advice that indicates a general approach or policy but gives no explicit techniques or tools.
$*P_3$	Infeasible Practice	A practice that would consume unreasonable resources (time, money).
$*P_4$	Security Expert	A practice requiring the expertise/deep knowledge of a security expert.
$*P_5$	IT Specialist	A practice executable by typical IT workers using basic professional knowledge of security.
$*P_6$	End-User	A practice executable by typical end-users.
T, T'	Desired Outcome	Advice suggesting a high-level goal but lacking a method by which to reach that outcome.
N	Security Principle	Advice that historically improves security outcomes, or reduces exposures.
M_{1A}	Unfocused	Multiple items on different topics or too wide a variety of aspects of the same topic.
M_{1B}	Unclear	Advice that does not make sense linguistically (e.g. unclear grammer).
M_2	Beyond Scope of Security	Advice that is hard to argue could possibly help security.

Fig. 5. SAcoding codes. $*$ donates actionable codes.

A total of 424 advice items were extracted from the six source documents. Each author then independently applied the SAcoding method to every advice item. Author one has 25 years of professional experience in the field of information security, is employed as a security researcher, holds an M.Sc. degree in Information Security, and is the author of a book on the history of information security. Author two has 18 years of professional experience in security, with a focus on the nuclear sector. He has published widely on organizational security issues in his role as a Professor of Science and International Security.

There were 9 disagreements, resulting in 97.9% inter-coder agreement. Per Halpin (2024), percentage agreement is an acceptable measure of inter-coder agreement where the codebook is straightforward and simple—as is the case with SAcoding, and the coders are experienced and have a good understanding of the codebook—as described above. Krippendorff's Alpha was calculated as 0.972. This measure of inter-coder agreement accounts for chance agreement, with scores approaching 1 indicating higher agreement. The 9 disagreements were resolved through discussion in order to reach a consensus, resulting in changes to 8 codes.

8 items were assigned two codes, which is permitted within the SAcoding method in cases where two codes apply. The total number of resulting codes was therefore 432. The overall process employed within the systematic analysis is shown in Fig. 6.

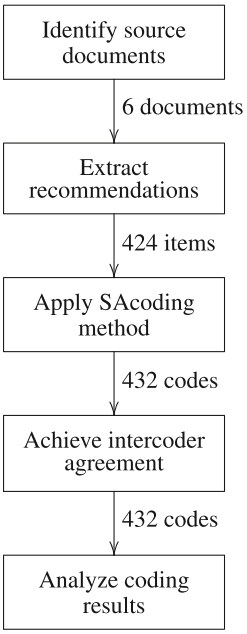

Fig. 6. Overall systematic analysis process.

4.1. Results of coding

Fig. 7 shows the coding results. Fig. 8 shows the contribution of each source document to each code. Fig. 9 illustrates the distribution of codes across the source documents. Fig. 10 displays the per-document proportion of actionable advice (i.e. advice items receiving P_3, P_4, P_5, or P_6 codes).

Below, each code is discussed in order of the percentage of total codes assigned.

$\boldsymbol{P_4}$ (*Security Expert*). The majority of items (41.9%) were coded as P_4. The proportion of items coded as P_4 varied widely across the source documents: 54.8% in the NITTF document but only 18.2% in the CISA document.

$\boldsymbol{P_5}$ (*IT Specialist*). 19.2% of items were coded as P_5. As with P_4, there was significant variation in the proportion of items coded as P_5: 38.2% in the SEI-CERT document but only 3.2% in the NITTF document.

$\boldsymbol{P_2}$ (*General Practice*). 16.2% of items were coded as P_2. While advice items that receive the P_2 code are not actionable according to the SAcoding method, they can still describe desirable goals. An example from the COESS document is the advice item: "*Develop repeatable*

	P_1	P_2	$*P_3$	$*P_4$	$*P_5$	$*P_6$	T, T'	N	M_{1A}	M_{1B}	M_2	n
CISA	4	12		14	13		2	23	4		5	77
COESS	19	37	4	58	7			4	5			134
FINRA	5	2		29	14			1	1		1	53
NITTF	3	10		17	1							31
SEI-CERT		6	2	56	47		3	1			8	123
SIFMA	1	3		7	1				2			14
Total	32	70	6	181	83		5	29	12		14	432
% of Total	7.4%	16.2%	1.4%	41.9%	19.2%	0.0%	1.2%	6.7%	2.8%	0.0%	3.2%	100%

Fig. 7. Coding results. 8 of 424 advice items received two codes, resulting in $n = 432$. $*$ donates actionable codes.

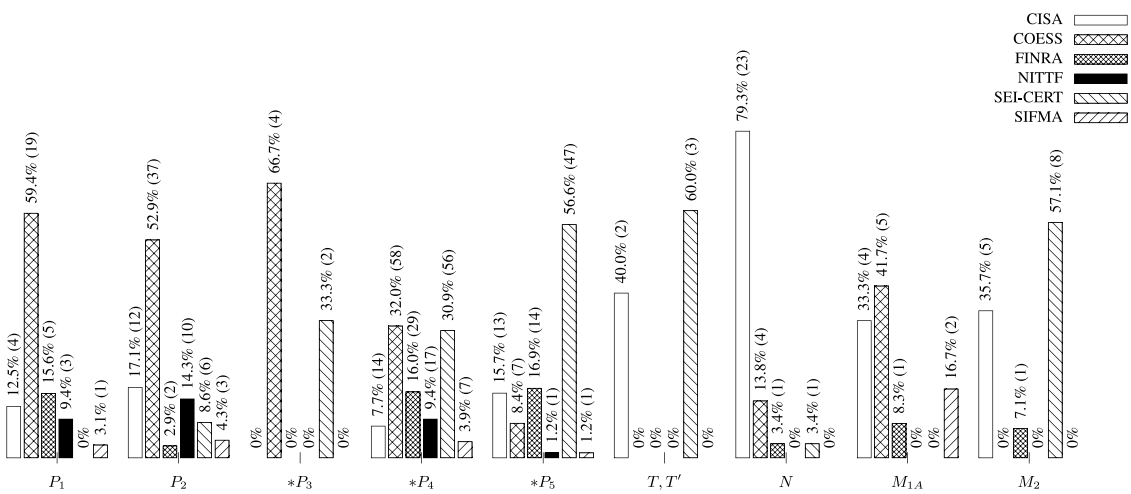

Fig. 8. Coding results: Contribution of source documents to codes. P_6 and M_{1B} are not shown as no advice items received those codes. $*$ donates actionable codes.

processes to achieve consistency in how insider threats are monitored and mitigated".

$\boldsymbol{P_1}$ (*Incompletely Specified Practice*). 7.4% of items were coded as P_1. Per the SAcoding approach, items coded P_1 are not actionable because they do not describe or imply steps or actions to take. For example, the advice item "*Do not rely exclusively on technology solutions; combine technical tools with human input, analysis, and intelligence to interpret technical data and identify anomalous insider behavior*" from the SIFMA document. This advice item is supported within the literature, such as by Greitzer and Frincke (2010) and by Schultz (2002), but the SIFMA document does not specify *how* to combine those various elements. 14.2% of items in the COESS document were coded as P_1, compared to none in the SEI-CERT document.

$\boldsymbol{N}$ (*Security Principle*). 6.7% of items were coded as N. All but six of these items ($n = 23$) were located in the CISA document. These are declarative statements such as "*Not all intentional insider threats are malicious*" and "*Exhibiting no indicators does not guarantee that a person will not pose an insider threat*".

$\boldsymbol{M_2}$ (*Beyond Scope of Security*). 3.2% of items were coded as M_2. As an example, the CISA document contains the advice item: "*While actual criminal violations should always be reported to local law enforcement, the threat management team should carefully consider the potential risks and benefits of requesting law enforcement assistance in a situation that does not rise to the level of a criminal act.*" The risks and benefits referred to within this advice item do not appear to relate directly to security, hence the resulting M_2 code.

$\boldsymbol{M_{1A}}$ (*Unfocused*). 2.8% of items were coded as M_{1A}, with the SIFMA document containing by far the largest proportion at 14.3% (the next closest being the CISA document at 5.2%). As an example, the CISA document contains the advice item: "*Regularly exercise the insider threat mitigation program, update its policies using a conditions-based as well as a temporal-based approach, and conduct regular audits of the program to ensure oversight and compliance.*" This item attempts to combine periodic testing, two types of policy updates, and regular auditing of the insider program.

$\boldsymbol{P_3}$ (*Infeasible Practice*). 1.4% of items were coded as P_3. Only the items that appeared to be plainly infeasible were coded as P_3. These items were located in the COESS ($n = 4$) and SEI-CERT ($n = 2$) documents. For example, the item "*Prohibit devices with cameras in sensitive areas*" from the SEI-CERT document could in theory be satisfied by creating a policy statement that simply asserts that policy, but to implement preventative controls would require body pat-downs or X-ray imaging of workers—such as in airport security screening.

$\boldsymbol{T, T'}$ (*Desired Outcome*). 1.2% of items were coded as T, and 0% as T'. As noted in Section 3, an outcome alone is not actionable, because an outcome alone does not also specify a method by which the outcome can be reached. For example, the SEI-CERT document contains the advice item "*Prevent sensitive documents from being printed if they are not required for business purposes*". This advice item attempts to address the very real risk of insiders exfiltrating confidential information using document printing (Everett, 2011; Mulligan, 2016). However, the SEI-CERT document does not also describe *how* to implement such a control. To determine which documents have legitimate business purpose to be printed, and to do so algorithmically and at scale would appear to be a non-trivial task.

$\boldsymbol{P_6}$ (*End-user*). No items received a code of P_6. As described above, SAcoding was originally developed in the context of assessing security advice items relating to IoT devices. In that context, the end-user is the user of those devices. In an organizational setting, the end-users would seem to be the population of workers within the organization who interact with security controls. For insider threats, those controls would include access controls, security training, security monitoring, and such-like. Because the advice items within the source documents are intended for the individuals within organizations who are *implementing* those security controls (per Section 3 above), none of the advice items are consequently intended for end-users.

$\boldsymbol{M_{1B}}$ (*Unclear*). No items received a code of M_{1B}. The six source documents are professionally produced with a high standard of copy editing.

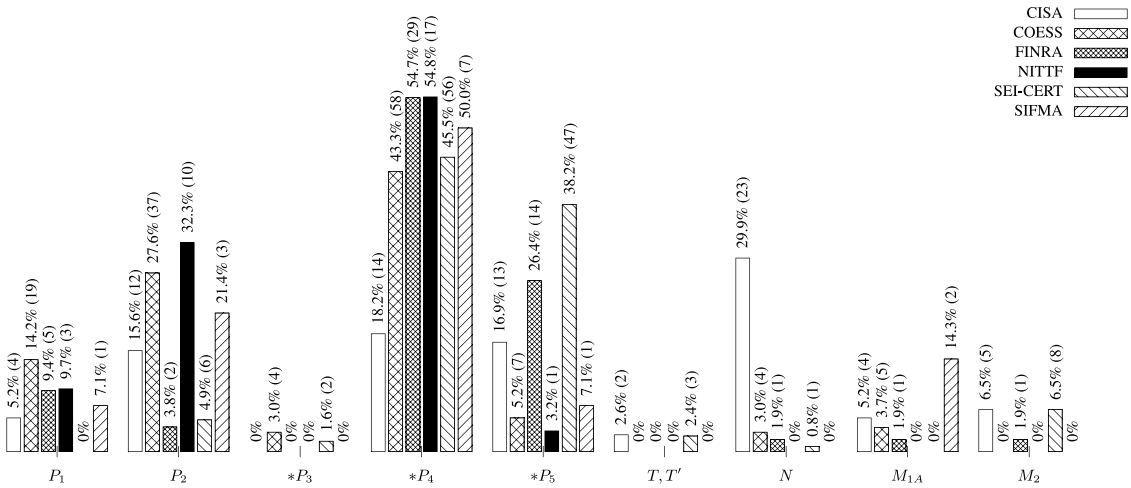

Fig. 9. Coding results: Distribution of codes across source documents. P_6 and M_{1B} are not shown as no advice items received those codes. $*$ donates actionable codes.

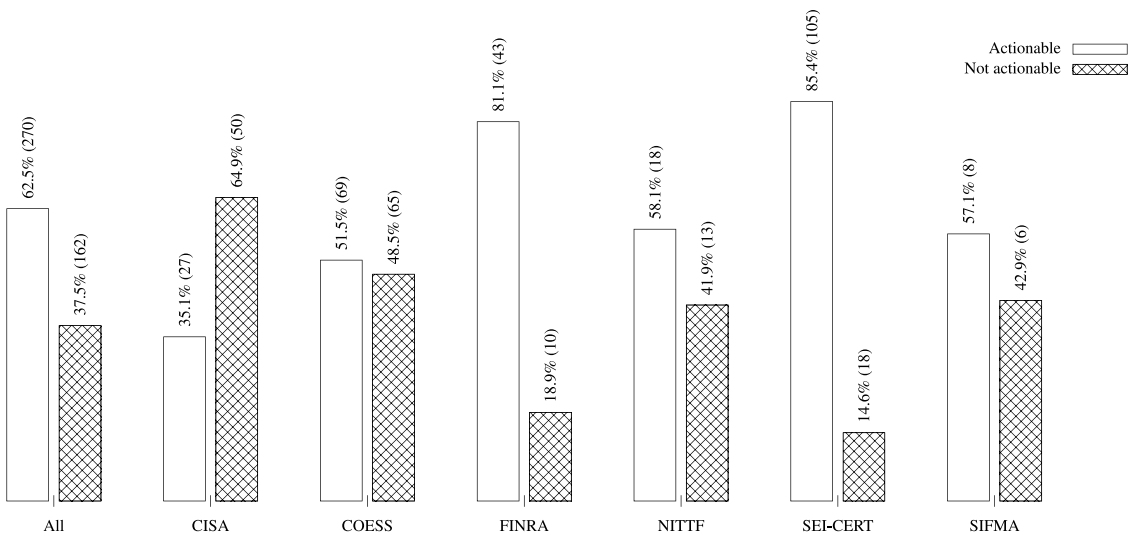

Fig. 10. Coding results: Per-document proportion of actionable advice (i.e. advice items receiving P_3, P_4, P_5, or P_6 codes).

4.2. Analysis of coding results

The coding exercise produced a number of interesting results. Here we analyze four notable features of those results: the proportion and quantity of actionable codes, the proportion of codes requiring expertise, and the degree to which the advice within the source documents relies on external sources of information.

Proportion of actionable codes. 62.5% of the total advice items were found to be actionable using the SAcoding method (i.e. that proportion of advice items received at least one actionable code). However, there was substantial variation in the proportion of actionable advice across the source documents. This finding has a direct implication for organizations who seek advice on the topic of insider threats. For example, an organization that selects the SEI-CERT document alone would receive advice items that are 85.4% actionable. If that same organization were instead to select the CISA document alone, they would receive advice items that are only 35.1% actionable. Unless they refer to this analysis or perform their own systematic analysis, organizations are unlikely to become aware of the proportion of actionable advice within the documents that are available to them. Given that all six source documents were selected for analysis precisely because they are freely available and are recently published by reputable authors, the relatively low proportion of actionable advice observed within the CISA, COESS, SIFMA, and NITTF documents could be problematic for organizations that select those documents. Specifically: that organizations may engage with those documents but only later determine that they offer little actionable advice. Systematic analysis reveals the proportion of actionable advice, but the task of performing a systematic analysis of multiple advice documents may itself be too costly for any single organization to carry out. In that case, multiple organizations could potentially collaborate and distribute the work amongst themselves. Organizations could also engage a third-party to implement the analysis, either individually or collectively. A second approach that does not require a systematic analysis to be performed would be to combine the advice items from multiple documents. This would have the effect of smoothing out the observed variation, but this task would itself require time and effort to perform and would generate a larger overall quantity of advice.

Quantity of actionable codes. The SEI-CERT document contains 104 actionable advice items (105 actionable codes, as one advice item received two actionable codes). The document with the next highest number of actionable advice items is the COESS document, with 69. As the quantity of advice increases, the task of prioritizing that advice becomes more difficult, and neither the SEI-CERT or COESS documents prioritize their advice items. Redmiles et al. (2020) find that priority ranking of advice is strongly correlated with advice adoption, and that both end-users and security experts struggle to prioritize advice. The

often unfalsifiable nature of security claims can also lead to the quantity of security advice increasing ever-larger, which leads to uncertainty regarding which specific advice is useful (versus the aggregate effect of all advice) (Herley, 2016; Herley and van Oorschot, 2017). Ideally, authors of advice documents would present a manageable amount of advice, and work to reduce advice inflation. This could be accomplished by deprecating advice that is no longer believed to be useful (Neil et al., 2023). However, none of the source documents describe having implemented such a process.

Proportion of codes requiring expertise. The high overall proportion of P_4 (*Security Expert*) and P_5 (*IT Specialist*) codes (41.9% and 19.2% respectively), implies that organizations will require staff with security and technical skills to implement the advice items within the source documents. As noted in Section 3, the SEI-CERT document identifies eight specific groups within organizations as its target audience, but only 16.3% of the advice items within the SEI-CERT document fall outside of the P_4 and P_5 codes. In addition, if the reasonable assumption is made that the cost of a security expert is greater than the cost of an IT specialist (because security is generally a less widely held skillset than IT), then organizations would presumably prefer that advice items receive a P_5 code in preference to a P_4 code—since the cost to implement those advice items would be lower. However, the reverse is true by a substantial margin across the six source documents evaluated. The implication for organizations is that currently, the implementation of controls intended to address insider threats appears to require both substantial security and IT expertise.

Smaller organizations are likely to feel the effect of this finding to a greater degree than larger organizations. This is because division of labor is more likely to be present in larger organizations, resulting in a higher likelihood that individuals with specialist skills are already present. Larger organizations may also have more resources with which to acquire specialist expertise. Where an organization does not possess the expertise required to implement advice items, one approach would be to utilize third-parties such as consulting firms. A second approach would be to improve the skill set of existing employees using specialized training.

Dependency on external references. Because of the high proportion of P_4 and P_5 codes, the quantity and quality of external references provided in the source documents becomes relevant. This is because an advice item can pass Q_5 (*Does it describe or imply steps or explicit actions to take?*), and subsequently receive a P_4 or P_5 code, but not provide *all* of the information required to implement the advice. For example, the P_4 coded advice item from the SEI-CERT document to "*Define and deploy insider threat indicators in an insider threat analytic hub that can detect potential precursors to insider threat activity*" does describe at a high level what steps to take, but those high level tasks must be comprised of a large number of smaller technical tasks including the selection of both indicators and an analytic hub in which to monitor them. The SIFMA document is the only source document that explicitly acknowledges this aspect, stating that "*This guide is meant only to provide a general framework for implementing an insider threat mitigation program. Outside experts can provide more tailored, detailed assistance and feedback*". All six of the source documents perhaps acknowledge this aspect implicitly, by providing references to external resources. The CISA document contains an appendix with 70 references and provides a short summary of each. It also refers the reader to the CISA web site. The COESS document contains 42 footnotes, of which 16 contain references. The FINRA document contains an appendix titled "*additional resources*" with 14 references, the NITTF document contains a section titled "*helpful references*" containing 8 items, the SEI-CERT document contains a bibliography with 116 references, and the SIFMA document contains a bibliography with 50 references that it describes as "*informative references*".

The question exists as to whether the references within the source documents are adequate to enable organizations to implement the various advice items. Only one of the references in the FINRA document is specifically on the topic of insider threats, which would seem to be insufficient. A related question is whether the references are organized in a useful way. The CISA document is the only source document to categorize its references, and then only into four broad themes. In the SIFMA document, only 25 of the 50 items in the bibliography are referenced in the body text, creating the impression of something of a disconnect between those two parts of the document.

On the basis of the systematic analysis alone, the documents that are most likely to be found useful by organizations are the SEI-CERT document, followed by the FINRA document. This is because those documents contain the highest proportion of actionable codes and the highest proportion of codes that are not actionable but that could potentially still impart useful information (N and P_2), while minimizing the number of advice items that receive other codes.

5. Practical guidance

While the six source documents are professionally produced and meet the specific criteria described in Section 2, only one of the documents provides information regarding the underlying data upon which the advice rests. Only two of the documents describe a research design (and one of those in a perfunctory manner). The documents were also found to vary widely in the proportion of advice items that are actionable, and that require technical expertise to implement. There is no prioritization of advice items, and the number of advice items appears unwieldy in some cases. The use of terminology is inconsistent, and can appear contradictory to the stated goals. The references provided are often scant and unorganized.

For these reasons, we provide the following items of practical guidance relating to these findings. The guidance is intended for both the producers of advice (document authors) and for the consumers of advice (organizations). Fig. 11 delivers an organizing framework, creating a through line for each item from *finding* to *implication*, and then to *guidance*.

(a) Limited or no methodological transparency. If an advice document does not describe the research design employed and underlying data utilized, then organizations cannot assess the veracity and generalizability of the claims regarding the security advice. Document authors should therefore explicitly declare and describe the research design and theoretical grounding. Organizations should identify and assess these aspects when evaluating advice documents, and be wary of simple assertions that the content is based on the knowledge of "experts". Such statements reduce the backing for the advice within those documents to the reputation of the author organization—which becomes merely an argument from authority.

(b) Inconsistent use of terminology; use of terminology that does not align with stated goals. Using a large number of different terms to describe advice may cause organizations to misinterpret that advice. Document authors should therefore employ consistent and appropriate terminology, and work to remove ambiguous terms. For example, describing advice as a "concept" can act as an indication that the advice is unlikely to be actionable. As noted in Section 3, terms such as "controls" and "mitigations" are traditionally used to describe end-states (or goals), but simply describing an end-goal is not useful unless the reader is also provided with a description of how to achieve that goal. As such, organizations can evaluate the terminology employed within a document as an indicator of document quality.

(c) Low proportion of actionable advice items. Advice that is not actionable is unlikely to be useful. Organizations might therefore incur opportunity costs by engaging with documents that offer minimal actionable advice. For document authors, our analysis demonstrates the utility of the SAcoding method for examining advice items of this type. A systematic analysis can reveal advice items that must be modified in order for them to become actionable. Items that receive an M_{1A} code should be split or clarified, and items that receive an M_{1B} code should be re-written. Items that receive other non-actionable codes

Finding	Implication	Guidance	
		For producers of advice (document authors)	*For consumers of advice (organizations)*
From the informal analysis:			
(a) Limited or no methodological transparency.	• Organizations cannot assess the veracity and generalizability of claims regarding security advice.	• Document the research design and underlying data utilized.	• Identify and assess the theoretical grounding and research design when evaluating documents.
(b) Inconsistent use of terminology; use of terminology that does not align with stated goals.	• Organizations may misinterpret advice.	• Employ consistent and appropriate terminology.	• Evaluate the terminology employed as an indicator of document quality.
From the systematic analysis:			
(c) Low proportion of actionable advice items.	• Organizations may incur opportunity costs by engaging with documents that offer minimal actionable advice.	• Identify non-actionable advice items, then re-write or remove those items. (⋆)	• Identify the ratio of actionable to non-actionable advice items when evaluating documents. (⋆)
(d) High proportion of advice items requiring expertise.	• Organizations require highly qualified professionals to implement advice.	• Provide advice that can be implemented by individuals with a spectrum of expertise. • Communicate the level of expertise required to implement advice in aggregate. (⋆)	• Identify which advice items require expertise. (⋆) • Determine the proportion of advice items that require expertise. (⋆) • Determine the costs of implementing advice across the organization. • Consider acquiring expertise through training or via third-parties.
(e) High number of actionable advice items; no prioritization of advice items.	• Organizations may struggle to prioritize and implement advice.	• Present a manageable amount of advice. • Prioritize advice items. • Remove or update advice items that are no longer relevant.	• Prioritize advice items where no prioritization is provided. • Incorporate factors specific to the organization into the prioritization of advice.
(f) Significant dependency on external references; references are not organized.	• Organizations require external information to implement advice. • Organizations must locate external guidance required to implement advice.	• Provide sufficient references to enable the implementation of advice. • Directly link advice items to their corresponding references.	• Identity advice that requires external information to implement. • Evaluate the reference information provided as an indicator of document quality.

Fig. 11. Organizing framework for practical guidance. Document authors and organizations seeking to implement items marked (⋆) may benefit from employing a method of systematic analysis, such as SAcoding.

(P_1, P_2, T, T', N, and M_2) should ideally be re-written so that they become actionable. If an advice item cannot be made actionable, then an evaluation should take place as to whether it should be included in the document. Organizations can perform their own systematic analysis to identify advice items that are not actionable, and to determine the proportion of actionable advice within each document. If that task is judged to be too burdensome, then organizations can potentially collaborate to distribute the effort amongst a group, or engage a third-party to perform the analysis. Advice that is coherent (i.e. that does not receive an M_{1A} or M_{1B} code), but is *not* actionable could still potentially be useful to organizations in other ways. Advice that receives a P_2, T, T', or N code could perhaps be used for the purpose of setting high-level goals, or for performing a gap analysis. It may also be possible for an organization to infer from those advice items what skill sets are required to achieve those goals, and then utilize that information for resource planning. Advice that receives a non-actionable code could potentially also be useful to an organization for communicating or comparing capabilities outside the organization, or between organizations. A second approach that would obviate the need to perform a systematic analysis would be to aggregate advice items from multiple documents. This would smooth out the variation in the proportion of actionable advice across documents, but have the effect of increasing the overall quantity of advice—advice that would ultimately still need to be evaluated.

(d) High proportion of advice items requiring expertise. The extent to which specialist expertise is required to implement the advice proffered in a document may not be immediately apparent to the reader. Document authors should therefore set that expectation in the text, and ideally for each individual advice item. This would help to convey the expected cost of implementation. Ideally, the advice presented within a document would span a spectrum of expertise, and not always require specialist knowledge. This would increase the probability that the advice could be implemented by organizations who do not already employ workers that hold that specialist knowledge. To bolster their expertise, organizations could train existing workers, hire additional workers, or hire third parties such as consultants, although all three of these options would require funds to carry out. Larger organizations may face the situation where they already employ workers with the required skills, but those workers are not located within the insider threat team. The insider threat team must then collaborate with the other relevant teams inside the organization to implement the advice—such as through joint initiatives and projects, or by negotiating the secondment of workers with specialized skills.

(e) High number of actionable advice items; no prioritization of advice items. A large quantity of advice is inherently difficult to

manage. One way that document authors can potentially reduce the overall quantity of advice is by systematically identifying and deprecating advice that is no longer appropriate. Document authors should also prioritize advice items, since the absence of prioritization decreases the likelihood of implementation. Even in the case where prioritization of advice items is provided within an advice document, organizations can and should incorporate organization-specific requirements into their particular prioritization of those items.

(f) Significant dependency on external references; references are not organized. If the task of implementing the advice within a document has a significant dependency on external sources of information, but the references to that information are not provided within the document, then the reader might be unable to locate the information and thus be unable to implement the advice. Therefore, if information that is external to the document is required, then document authors should set this expectation in the text and provide the necessary external references. In order to maintain the connection within the document between advice items and the relevant references, those references should be explicitly associated with advice items (such as by using footnotes), rather than being provided en masse in an appendix. Organizations should identify those advice items that require additional information, but where no external references are provided. The most likely candidates are advice items that receive P_4 or P_5 codes, due to the often complex nature of technical controls. The presence or absence of that reference information can then be used by organizations as an indicator of document quality, for the purpose of helping to guide document selection.

All six of the documents evaluated in this article contain actionable advice on the topic of insider threats. Our goal in providing the practical guidance above is to enable document authors to further improve these and other documents, and to assist organizations in their selection and productive use of such documents.

6. Feedback on the SAcoding methodology

Barrera et al. (2023b) describe SAcoding as a generic method for coding security advice. They employ SAcoding to code advice intended for IoT product manufacturers on the topic of IoT security. In this paper, we have employed SAcoding to code advice intended for organizations on the topic of insider threats. Given that we have employed SAcoding to analyze security advice in a new category (advice intended specifically for organizations), and for a new topic (advice on the topic of insider threats), we are able to offer feedback on the SAcoding method, which we present below.

Applicability to the organizational context. The portion of the SAcoding tree that begins at Q_7 sorts advice items into a specific practice that is performed by either an end-user, an IT specialist, or a security expert. Within a large organization it is unlikely that every relevant IT specialist and security expert will be located in the insider threat team. This is because advice on the topic of insider threats tends to span a wide variety of topic areas such as access management, monitoring, training, backups, and so-on. As such, an alternative approach to Q_7 that could potentially be useful to organizations would be to code the advice items according to the responsibility for implementation. To accomplish this, a replacement Q_7 might read: "*What is the role of the insider threat team with regard to this item?*" The resulting codes could then employ the RACI model (PMI, 2013, p. 262), which is an established approach to categorizing participation in task or project delivery within an organization:

- P_R (*Responsible*)
- P_A (*Accountable*)
- P_C (*Consulted*)
- P_I (*Informed*)

This coding would help the insider threat team to understand where the cost of implementing advice would fall. The expectation would be that advice items that receive a P_R code will create the greatest resource burden on the insider threat team if those advice items were to be implemented. The other codes would impose a progressively lower resource burden on the insider threat team ($P_R > P_A > P_C > P_I$). If document authors find that advice largely falls inside or outside the responsibility of the insider threat team, this expectation could be set within the document (in much the same way as with the discussion regarding the proportion of codes that require expertise in Section 4.2).

Sensitivity to organizational size. The word "reasonable" in Q_6 ("*Is it viable to accomplish with reasonable resources?*") could be interpreted as "reasonable for the average organization", or as "reasonable for the organization in question". In the case of the latter interpretation, Q_6 becomes highly sensitive to the size of the organization, because larger organizations typically have more resources at their disposal than smaller organizations. As such, differences in coding results across organizations could be affected by a hidden variable—namely the size of the organization. Although the CISA document claims that it can be used by organizations of any size, three other source documents indicate that size should be a consideration when considering their advice. To address this issue, Q_6 could have two mutually exclusive forms. For a given coding exercise, the coder would select either Q_{6a} "*Is it viable to accomplish with reasonable resources for the average organization?*" or Q_{6b} "*Is it viable to accomplish with the resources typically available to an organization of size X?*" (where the value of X is specified). It may be more useful to measure X in some other way, such as with available budget. When sharing coding datasets, the selected version of question Q_6 and the nature of the X property would need to also be provided.

Sensitivity to the presence of domain knowledge. In a similar manner to the above, Q_2 ("*Is it arguably helpful for security?*") appears to be highly sensitive to the presence of domain knowledge. For example, unhappiness and disgruntlement have been identified as factors that contribute to the likelihood that an insider will carry out a malicious action (Herbig, 2017; Jaros et al., 2019). Consequently, when answering Q_2 with regard to the advice item "*Expect and model transparent and respectful communication*" from the SEI-CERT document, a person who possesses that domain knowledge is more likely to answer in the affirmative. But without that specific domain knowledge, it might be difficult to understand how the advice item is helpful for security.

Usability. Three of the SAcoding questions use negation, whereas the remaining eight questions use affirmation. For example, Q_6 ("*Is it viable to accomplish with reasonable resources?*") uses affirmation, whereas Q_{1A} ("*Is the advice item unfocused?*") uses negation. Because the majority of questions use affirmation, answering any of the questions that use negation requires the reader to perform a cognitive shift (or task switch) that involves a change from processing questions that use affirmation to processing a question that uses negation. This aspect could be addressed by rewording the three questions that currently use negation to instead use affirmation. Q_{1A} could become "*Is the advice item focused?*", Q_{1B} could become "*Is the advice item clear?*", and Q_3 could become "*Does it describe how to achieve a desired outcome?*"

7. Limitations

We note the following limitations of this work. Firstly, that when organizations use documents that provide advice on the topic of insider threats, the possibility exists that this action is simply performative. For example, organizations might use advice documents solely in order to demonstrate commitment to interested parties such as auditors and regulators. In this case, the quality of advice has little significance, beyond perhaps some basic level of face validity.

Secondly, that the six source documents were selected and analyzed based on specific criteria, but this process naturally excludes other advice documents on the topic of insider threats that exist. Although

the specific criteria and search strategy were chosen for the purpose of identifying documents that organizations would be likely to select, organizations might employ different criteria or different search strategies. This limitation is mitigated by the analysis being carried out on six distinct source documents and 424 total advice items. The analysis of six source documents also serves the purpose of generating initial results on this topic.

Thirdly, that more useful results might be obtained by using an alternative method to SAcoding. SAcoding was designed to enable the systematic analysis of security advice. It is therefore a good match for the scenario described in this paper, where multiple coders must code a large quantity of advice using a consistent scheme. It is entirely plausible that a security expert with specific knowledge regarding a particular organization might assess the advice in a manner that would produce results that are more suited to that particular organization. An organization might not employ such a security expert who possesses that knowledge, however. A second issue is where experts differ. Barrera et al. (2023b) describe how "*intuitive understandings are at best foggy and differ considerably across even experts*". If the experts employed by an organization disagree, a method for reconciling results would be required—which leads back to methods such as SAcoding.

8. Related work

As shown in Section 2, there are a relatively small number of documents that specifically focus on the topic of providing advice to organizations regarding insider threats, and that meet the criteria described. Those documents are also grey literature, in that they do not claim to be peer-reviewed, and are not published via traditional academic publishing channels.

When considering academic studies on the topic of security advice more broadly, the extant literature tends to focus on particular scenarios in which advice is presented. A common scenario is where end-users are presented with advice. This scenario is relevant when the decisions of end-users can impact security, such as when end-users receive phishing emails (Hong et al., 2013; Kumaraguru et al., 2010; Naqvi et al., 2023). For example, Redmiles et al. (2018) measure the readability of 1878 advice items intended for end-users, and find that only 22% would be understandable at what they describe as a 'standard level' of reading ability. Reeves et al. (2023) find that when presented with Security Education Training and Awareness (SETA) videos in a corporate setting, employees are influenced by their beliefs regarding the motivation of the larger corporation. Redmiles et al. (2016) find that end-users reject security advice for a variety of reasons, including the advice being considered too advanced for their skill set, when they feel they do not have direct responsibility for security, and when they perceive advice as being too marketing-oriented. Herley (2009) finds such rejection of security advice by end-users to be rational, since security advice typically represents a poor cost–benefit tradeoff for individuals.

A second common scenario is where software developers are provided with advice with the goal of improving software security. With suitable guidance, developers can reduce the likelihood of introducing software vulnerabilities into code (Garfinkel and Lipford, 2014, p. 56; Lopez et al., 2023). Acar et al. (2017) analyze 19 general advice resources intended for developers, and find that many of those resources failed to include advice on important topics relating to software security such as logging and program-analysis tooling.

If the meaning of 'advice' is broadened even further, to mean any information that could potentially be useful to organizations, then much of the literature on the topic of insider threats could be considered to contain advice. Articles from the technical domain on relevant topics such as access control and security monitoring could be useful to organizations for implementing or tuning such systems. Similarly, articles from the sociological domain on relevant topics such as psychological factors and behavioral theories could be beneficial to organizations for creating security controls such as employee vetting procedures and security awareness training. Because this information is diffused within the literature, survey articles become a useful resource. Hunker and Probst (2011) survey and then describe a number of technological, sociological, and socio-technical approaches to tackling insider threats. Liu et al. (2018) propose three categories of insider threat ('masquerader', 'traitor', and 'unintentional perpetrator'), and survey existing work against those categories. Gheyas and Abdallah (2016) survey insider threat detection, focusing on research trends, challenges, and algorithms. Ko et al. (2017) also survey insider threat detection mechanisms, but through the lens of behavior types. Homoliak et al. (2019) identify and detail four categories of insider threat research: incidents and datasets, analysis of incidents, simulations, and defense solutions. Song et al. (2023) survey preventative and detective methods used to address insider threats, and organize them around a lifecycle model of an insider threat attack. Manoharan et al. (2024) also survey detection techniques, focusing on machine learning algorithms. Al-Mhiqani et al. (2024) review and analyze the detection of insider threats to cyber–physical systems such as with IoT devices. On the other side of the equation, Inayat et al. (2024) survey attack techniques employed by malicious insiders, and propose a multi-tiered monitoring model in response. In order to extract advice from the greater body of literature, an efficient approach that organizations could employ would be to review survey articles such as these.

The above referenced literature provides a variety of advice on the topic of insider threats, and on the nature of advice more broadly. However, the perspective of organizations as the end-users of advice has not often been considered. As such, our work here is motivated in large part by a desire to increase knowledge and understanding of this aspect.

9. Conclusion

A number of documents provide advice to organizations on the topic of insider threats. Where those documents are freely available and have reputable authors, organizations may follow the advice they contain. As such, the quality of that advice matters. The main contribution of this work has been to analyze documents of this type, both systematically and in an informal manner. Documents that are gray literature are less likely to be evaluated in an academic setting, and so we offer our analysis here as a contribution in that regard. It is also important for the research community to provide productive feedback to the authors of advice documents, so that more effective advice can be created and promulgated.

This paper has primarily focused on identifying and analyzing the differences between advice documents in terms of the proportion of actionable advice, and to a lesser extent the other properties described in Sections 3 and 4. Future work could seek to replicate this analysis, or expand upon it by exploring other differences between advice documents. For example, most advice documents that fit the specific criteria described in Section 2 are authored by U.S. based organizations (with the exception of the COESS document as noted). Further analysis could use different criteria to select advice documents created by author organizations in several countries, for the purposes of performing a cross-national analysis. Another interesting property of advice documents is how they change over time. A longitudinal analysts could be carried out to determine whether the content of advice documents align or diverge with contemporary techniques employed by malicious insiders. A different category of future work could examine differences in the consumption of security advice by organizations. For example, a comparative analysis could analyze organizations in different sectors. The extent to which certain advice documents are more suited to certain sectors could then be explored.

As a final item of note, we underscore the importance of tools such as SAcoding, since these tools enable work of this type to be carried out by both researchers and organizations. We employed SAcoding

here in a novel way: to analyze advice that is specifically intended for organizations, and on the topic of insider threats. We also offered suggestions for how SAcoding could possibly be improved.

The task of addressing insider threats naturally falls on both the producers and consumers of advice; on both researchers and organizations. It is a collective effort, and we hope this work will benefit both groups.

CRediT authorship contribution statement

Andrew Stewart: Writing – original draft, Methodology, Investigation, Formal analysis, Data curation, Conceptualization. **Christopher Hobbs:** Writing – review & editing, Supervision.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

References

Acar, Y., Stransky, C., Wermke, D., Weir, C., Mazurek, M.L., Fahl, S., 2017. Developers need support, too: A survey of security advice for software developers. In: Proc. of IEEE Cybersecurity Development. SecDev, IEEE, Cambridge, MA, http://dx.doi.org/10.1109/SecDev.2017.17.

Al-Mhiqani, M.N., Alsboui, T., Al-Shehari, T., Abdulkareem, K.H., Ahmad, R., Mohammed, M.A., 2024. Insider threat detection in cyber-physical systems: A systematic literature review. Comput. Electr. Eng. 119 (A), http://dx.doi.org/10.1016/j.compeleceng.2024.109489.

BaMaung, D., McIlhatton, D., MacDonald, M., Beattie, R., 2018. The enemy within? The connection between insider threat and terrorism. Stud. Confl. Terror. 41 (2), 133–150. http://dx.doi.org/10.1080/1057610X.2016.1249776.

Barrera, D., Bellman, C., van Oorschot, P., 2023a. A close look at a systematic method for analyzing sets of security advice. J. Cybersecur. 9 (1), http://dx.doi.org/10.1093/cybsec/tyad013.

Barrera, D., Bellman, C., van Oorschot, P., 2023b. Security best practices: A critical analysis using IoT as a case study. ACM Trans. Priv. Secur. 26 (2), 1–30. http://dx.doi.org/10.1145/3563392.

Bellman, C., van Oorschot, P., 2023. Systematic analysis and comparison of security advice as datasets. Comput. Secur. 124, http://dx.doi.org/10.1016/j.cose.2022.102989.

Bunn, M., Sagan, S.D., 2016. Insider Threats. Cornell University Press, URL https://www.cornellpress.cornell.edu/book/9781501706493/insider-threats.

Cappelli, D., Moore, A., Trzeciak, R., 2012. The CERT Guide to Insider Threats: How to Prevent, Detect, and Respond to Information Technology Crimes. Addison-Wesley.

CISA, 2020. Insider Threat Mitigation Guide. Cybersecurity and Infrastructure Security Agency (CISA), URL https://www.cisa.gov/resources-tools/resources/insider-threat-mitigation-guide.

Claycomb, W.R., Huth, C.L., Philips, B., Flynn, L., McIntire, D., 2013. Identifying indicators of insider threats: Insider IT sabotage. In: 47th International Carnahan Conference on Security Technology. ICCST, IEEE, Medellín, Colombia, http://dx.doi.org/10.1109/CCST.2013.6922038.

Claycomb, W.R., Nicoll, A., 2012. Insider Threats to Cloud Computing: Directions for New Research Challenges. Software Engineering Institute (SEI).

COESS, 2019. Insider Threat Program Development Manual. Confederation of European Security Services (COESS).

Costa, D.L., Albrethsen, M.J., Collins, M.L., Perl, S.J., Silowash, G., Spooner, D., 2016. An Insider Threat Indicator Ontology. Software Engineering Institute (SEI), URL https://insights.sei.cmu.edu/library/an-insider-threat-indicator-ontology/.

Dill, D.L., Rubin, A.D., 2004. Guest editors' introduction: E-voting security. IEEE Secur. Priv. 2 (1), 22–23, URL https://doi.ieeecomputersociety.org/10.1109/MSECP.2004.1264849.

Epstein, J., 2008. Security lessons learned from Société Générale. IEEE Secur. Priv. 6 (3), 80–82. http://dx.doi.org/10.1109/MSP.2008.71.

Everett, C., 2011. Printers: The neglected threat. Netw. Secur. 2011 (9), 8–11. http://dx.doi.org/10.1016/S1353-4858(11)70095-2.

FINRA, 2023. Insider Threats: Effective Controls and Practices. Financial Industry Regulatory Authority (FINRA), URL https://www.finra.org/compliance-tools/Industry_Risks_and_Threats/Effective_Controls_and_Practices.

Garfinkel, S., Lipford, H.R., 2014. Usable Security: History, Themes, and Challenges. Morgan & Claypool.

Gheyas, I.A., Abdallah, A.E., 2016. Detection and prediction of insider threats to cyber security: A systematic literature review and meta-analysis. Big Data Anal. 1 (6), http://dx.doi.org/10.1186/s41044-016-0006-0.

Greitzer, F.L., Frincke, D.A., 2010. Combining traditional cyber security audit data with psychosocial data: Towards predictive modeling for insider threat mitigation. In: Probst, C., Hunker, J., Gollmann, D., Bishop, M. (Eds.), Insider Threats in Cyber Security.. Springer, pp. 85–113. http://dx.doi.org/10.1007/978-1-4419-7133-3_5.

Halpin, S.N., 2024. Inter-coder agreement in qualitative coding: Considerations for its use. Am. J. Qual. Res. 8 (3), 23–43. http://dx.doi.org/10.29333/ajqr/14887.

Herbig, K.L., 2017. The expanding spectrum of espionage by Americans, 1947–2015. Defense Personnel and Security Research Center, URL https://www.dhra.mil/PERSEREC/Selected-Reports/#TR17-10.

Herley, C., 2009. So long, and no thanks for the externalities: The rational rejection of security advice by users. In: New Security Paradigms Workshop. NSPW, Oxford, UK, http://dx.doi.org/10.1145/1719030.1719050.

Herley, C., 2016. Unfalsifiability of security claims. Proc. Natl. Acad. Sci. 113 (23), 6415–6420. http://dx.doi.org/10.1073/pnas.1517797113.

Herley, C., van Oorschot, P.C., 2017. SoK: Science, security and the elusive goal of security as a scientific pursuit. In: Proc. of the 2017 IEEE Symposium on Security and Privacy. IEEE, San Jose, CA, http://dx.doi.org/10.1109/SP.2017.38.

Homoliak, I., Toffalini, F., Guarnizo, J., Elovici, Y., Ochoa, M., 2019. Insight into insiders and IT: A survey of insider threat taxonomies, analysis, modeling, and countermeasures. ACM Comput. Surv. 52 (2), 1–40. http://dx.doi.org/10.1145/3303771.

Hong, K.W., Kelley, C.M., Tembe, R., Murphy-Hill, E., Mayhorn, C.B., 2013. Keeping up with the Joneses: Assessing phishing susceptibility in an email task. Proc. Hum. Factors Ergon. Soc. Annu. Meet. 57 (1), 1012–1016. http://dx.doi.org/10.1177/1541931213571226.

Hunker, J., Probst, C.W., 2011. Insiders and insider threats: An overview of definitions and mitigation techniques. J. Wirel. Mob. Netw. 2 (1), 4–27.

Inayat, U., Farzan, M., Mahmood, S., Zia, M.F., Hussain, S., Pallonetto, F., 2024. Insider threat mitigation: Systematic literature review. Ain Shams Eng. J. 15 (12), http://dx.doi.org/10.1016/j.asej.2024.103068.

Jaros, S.L., Rhyner, K.J., McGrath, S.M., Gregory, E.R., 2019. The Resource Exfiltration Project: Findings from DoD Cases, 1985–2017. Defense Personnel and Security Research Center, URL https://www.dhra.mil/PERSEREC/Selected-Reports/#TR19-02.

Ko, L.L., Divakaran, D.M., Liau, Y.S., Thing, V.L., 2017. Insider threat detection and its future directions. Int. J. Secur. Netw. 12 (3), 168–187. http://dx.doi.org/10.1504/IJSN.2017.084391.

Kumaraguru, P., Sheng, S., Acquisti, A., Cranor, L.F., Hong, J., 2010. Teaching Johnny not to fail for phish. ACM Trans. Internet Technol. 10 (2), 1–31. http://dx.doi.org/10.1145/1754393.1754396.

Liu, L., Vel, O.D., Han, Q.L., Zhang, J., Xiang, Y., 2018. Detecting and preventing cyber insider threats: A survey. IEEE Commun. Surv. Tutor. 20 (2), 1397–1417. http://dx.doi.org/10.1109/COMST.2018.2800740.

Lopez, T., Sharp, H., Bandara, A., Tun, T., Levine, M., Nuseibeh, B., 2023. Security responses in software development. ACM Trans. Softw. Eng. Methodol. 128 (3), http://dx.doi.org/10.1145/3563211.

Luckey, D., Stebbins, D., Orrie, R., Rebhan, E., Bhatt, S.D., Beaghley, S., 2019. Assessing Continuous Evaluation Approaches for Insider Threats: How Can the Security Posture of the U.S. Departments and Agencies Be Improved?. RAND Corporation, http://dx.doi.org/10.7249/RR2684.

Manoharan, P., Yin, J., Wang, H., Zhang, Y., Ye, W., 2024. Insider threat detection: A review. In: Proc. of International Conference on Networking and Network Applications. NaNA, IEEE, Yinchuan City, China, pp. 147–153, URL https://doi.ieeecomputersociety.org/10.1109/NaNA63151.2024.00031.

Michaud, E.C., 2010. Museum security and the Thomas Crown affair. J. Phys. Secur. 4 (1), 31–35, URL https://www.osti.gov/biblio/1043148-museum-security-thomas-crown-affair.

Mulligan, W., 2016. Printing: The hidden threat for your business. Comput. Fraud Secur. 2016 (12), 18–20. http://dx.doi.org/10.1016/S1361-3723(16)30101-4.

Naqvi, B., Perova, K., Farooq, A., Makhdoom, I., Oyedeji, S., Porras, J., 2023. Mitigation strategies against the phishing attacks: A systematic literature review. Comput. Secur. 132, http://dx.doi.org/10.1016/j.cose.2023.103387.

Neil, L., Ramulu, H.S., Acar, Y., Reaves, B., 2023. Who comes up with this stuff? Interviewing authors to understand how they produce security advice. In: Proc. of the 10th Symposium on Usable Privacy and Security. SOUPS, Anaheim, CA, URL https://www.usenix.org/system/files/soups2023-neil.pdf.

NIST, 2024. Insider Threat. National Institute of Science and Technology (NIST), Retrieved May 29, 2024, from URL https://csrc.nist.gov/glossary/term/insider_threat.

NITTF, 2024. Insider Threat Guide: A Compendium of Best Practices to Accompany the National Insider Threat Minimum Standards. National Insider Threat Task Force (NITTF), https://www.dni.gov/files/NCSC/documents/nittf/20240926_NITTF-Insider-Threat-Guide.pdf.

Petrie, E., Evans, C., 2019. Piloting the exchange of insider threat reports: Information sharing challenges to proactive cyber fraud identification. SWIFT Institute, http://dx.doi.org/10.2139/ssrn.3392258.

Pilch, R.F., Zilinskas, R.A., 2005. Diane Thompson: A case study. In: Pilch, R.F., Zilinskas, R.A. (Eds.), Encyclopedia of Bioterrorism Defense. Wiley, http://dx.doi.org/10.1002/0471686786.ebd0118.

PMI, 2013. A Guide to the Project Management Body of Knowledge (PMBOK Guide), Fifth Edition Project Management Institute (PMI).

Redmiles, E.M., Kross, S., Mazurek, M.L., 2016. How I learned to be secure: A census-representative survey of security advice sources and behavior. In: Proc. of the 23rd ACM SIGSAC Conference on Computer and Communications Security. ACM, Vienna, Austria, http://dx.doi.org/10.1145/2976749.2978307.

Redmiles, E.M., Morales, M., Maszkiewicz, L., Stevens, R., Liu, E., Kuchhal, D., Mazurek, M.L., 2018. First steps toward measuring the readability of security advice. In: Proc. of the 2018 IEEE Security & Privacy Workshop on Technology and Consumer Protection. ConPro, IEEE, San Francisco, CA, URL https://www.ieee-security.org/TC/SPW2018/ConPro/papers/redmiles-conpro18.pdf.

Redmiles, E.M., Warford, N., Jayanti, A., Koneru, A., Kross, S., Morales, M., Stevens, R., Mazurek, M.L., 2020. A comprehensive quality evaluation of security and privacy advice on the web. In: Proc. of the 29th USENIX Security Symposium. USENIX, Boston, MA, pp. 89–108, URL https://www.usenix.org/system/files/sec20-redmiles.pdf.

Reeves, A., Calic, D., Delfabbro, P., 2023. Generic and unusable: Understanding employee perceptions of cybersecurity training and measuring advice fatigue. Comput. Secur. 128, http://dx.doi.org/10.1016/j.cose.2023.103137.

Schultz, E.E., 2002. A framework for understanding and predicting insider attacks. Comput. Secur. 21 (6), 526–531. http://dx.doi.org/10.1016/S0167-4048(02)01009-X.

SEI-CERT, 2023. CERT Common Sense Guide to Mitigating Insider Threats, Seventh Edition Software Engineering Institute (SEI).

SIFMA, 2018. Insider Threat Best Practices Guide, Second Edition Securities Industry and Financial Markets Association (SIFMA), URL https://www.sifma.org/resources/general/best-practices-for-insider-threats/.

Song, C., Zhang, J., Ma, L., Hu, X., Zheng, J., Yang, L., 2023. Insider threat defense strategies: Survey and knowledge integration. In: Proc. of the 17th International Knowledge Science, Engineering and Management Conference. Birmingham, United Kingdom, URL https://link.springer.com/chapter/10.1007/978-981-97-5489-2_10.

Wallace, R.J., Loffi, J.M., 2014. The unmitigated insider threat to aviation (part 1): A qualitative analysis of risks. J. Transp. Secur. 7 (4), 289–305.

Wilder, U.M., 2017. The psychology of espionage and leaking in the digital age. Stud. Intell. 61 (2), URL https://www.cia.gov/static/db3b29681fc4ba71b0220d16bb979ddd/Psych-of-Leaking-Espionage.pdf.

Andrew Stewart is a Ph.D. student within the School of Security Studies at King's College London. His current professional and academic research focus is insider threats. Andrew received his M.Sc. in Information Security from Royal Holloway, University of London. He is the author of A Vulnerable System: The History of Information Security in the Computer Age (Cornell University Press, 2021).

Christopher Hobbs is a Professor of Science and International Security within the Department of War Studies at King's College London, and Director of the King's Institute for Applied Security Studies. He holds a Ph.D. in physics from the University of London and a MPhys from Oxford University. He is a member of the Executive Advisory Board for the International Nuclear Security Forum (INSF), Associate Fellow of Advance HE and former Chair of the International Nuclear Security Education Network (INSEN). From 2014 to 2022 he served as Programme Director for the UK's Nuclear Security Culture Programme (NSCP).